



File No.: EXP202204881

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following:
BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on April 3, 2022. The complaint is directed against DIGI SPAIN TELECOM, S.L. with NIF B84919760 (hereinafter, the respondent or DIGI). The reasons on which the complaint is based are as follows:

The claimant states that on April 1, 2021, his mobile phone lost service, which he did not consider important, and hours later, he received several emails from two banking entities notifying him of attempts to access his account and the execution of several transfers via Bizum.

Upon contacting the respondent entity, they indicated that a duplicate of his SIM card had been issued.

Date on which the claimed events occurred: April 1, 2021.

Relevant documentation provided by the claimant:

- Copy of the complaint filed with the Civil Guard on April 1, 2021.
- Screenshot from the Customer Service of the respondent entity (dated April 12, 2021) in which they provide the claimant with the details of the point of sale where the duplicate SIM card was activated, on April 1, 2021, at 14:52h, adding the following: "We inform you that distributors are obliged to request the identity document of the holder to issue a duplicate of the SIM card."

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on May 30, 2022, as evidenced by the acknowledgment of receipt in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

On June 28, 2022, this Agency received a response indicating:

"In relation to the situation presented by the claimant, DIGI has been able to verify that, on April 1, 2021, the claimant contacted this company informing that he did not have service on his mobile line, as well as indicating that a duplicate of his SIM card had been issued which he had not requested. As soon as these facts were reported by the claimant, DIGI proceeded to the immediate and precautionary suspension of his mobile number, leaving the claimant's mobile line blocked to prevent any unauthorized use thereof.

Subsequently, on April 2, 2021, the claimant requested information from this company regarding the duplicate SIM card issued for his number.

On the same day, at 17:51hrs, the claimant, after visiting a Point of Sale, recovered the suspended line by acquiring a new duplicate of his card.

Furthermore, as can be observed, regarding the alleged irregular issuance of the duplicate SIM card, DIGI has been able to confirm that it was issued on April 1, 2021, at 14:52hrs, at a Distribution Point for DIGI products and services. In this regard, DIGI has been able to confirm that once the claimant recovered his mobile line, the situation was duly regularized.

Therefore, having presented the events that occurred, it has been determined that the cause that motivated this complaint is the alleged irregular issuance of a duplicate SIM card under the impersonation of the claimant's identity."

THIRD: In accordance with Article 65 of the LOPDGDD, when a complaint is presented to the Spanish

Agency for Data Protection (hereinafter, AEPD), it must evaluate its admissibility for processing, notifying the claimant of the decision on the admission or inadmissibility for processing within three months from the date the complaint was received by this Agency. If, after this period, such notification does not occur, it will be understood that the processing of the complaint continues in accordance with the provisions of Title VIII of the Law. This provision also applies to the procedures that the AEPD must process in exercising the powers conferred upon it by other laws.

In this case, taking into account the above and that the complaint was filed with this Agency on April 3, 2022, it is communicated that the complaint has been admitted for processing on July 3, 2022, as three months have passed since it was received by the AEPD.

FOURTH: The General Subdirector for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/18

in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

RESULT OF THE INVESTIGATION ACTIONS

(...)

FIFTH: On January 13, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR.

SIXTH: On January 23, 2023, DIGI requested a copy of the file and an extension of the legal deadline granted to respond to the request.

SEVENTH: On February 7, 2023, a written submission was received at this Agency, in due time and form, from the representative of DIGI, which, in summary, reiterates the allegations previously presented, first chronologically outlining how the events occurred, indicating the security protocol and the measures adopted regarding these events, stating that DIGI has not provided the alleged criminals with personal information of the complainant other than what they already had prior, because the established facts demonstrate that the identity thief knew the complainant's personal data beforehand: name and surname, ID number, and phone number.

Therefore, they indicate that there is no relationship between the facts identified by the AEPD as proven and the legal qualification made of them. The fact that the person carrying out the procedures does not correspond, supposedly, to the complainant who is the holder of the contract does not in itself imply that there is any lack of legitimacy in their processing, and much less does it imply per se that there is a lack of diligence in the actions of the company automatically.

Consequently, they indicate that it is not possible to associate DIGI with the performance of an unlegitimized processing of personal data, given that its actions are limited to complying with its processes and obligations.

That is to say, they state that during the process of requesting and delivering the duplicate, there is a processing of the personal data provided to DIGI in order for it to verify the identity of the interlocutor, first by telephone means and subsequently in person.

Furthermore, DIGI states that it is evidenced that the identity theft and the illegitimate access to the complainant's data occurred prior to any contact with DIGI; the alleged impersonator had in their possession the complainant's personal data, including their bank account (which also allowed them to access it).

On the other hand, it points out that the AEPD unequivocally imposes on DIGI an objective responsibility, in which, regardless of the diligence and measures deployed, the culpability of the entity is declared. The AEPD seems to confuse the concept of proactive responsibility with the obligation of

result imposed by objective responsibility. In this case, there is evidence of strict control, both prior to and after the request for the duplicate, the establishment of prior and subsequent measures, as well as the existence of measures aimed at preventing these practices beforehand.

This is why the respondent considers that the present Agreement to initiate is not legally justified, as it imposes on DIGI an obligation of result, based solely on the harmful outcome produced by the fraudulent activity of a third party, without taking into account the diligence used and without considering the deployment of technically adequate and implemented measures.

Additionally, it points out that the following mitigating circumstances exist in the present case that have not been considered in the appropriate grading of the sanction:

The absence of prior infringements committed by DIGI (art. 83.2 e) GDPR).

At no time have special categories of data been processed (Art. 83.2 g) GDPR).

The degree of cooperation of DIGI with the AEPD in order to remedy a supposed infringement and mitigate its possible adverse effects (art. 83.2 f) GDPR).

The nonexistent benefit obtained (Art. 83.2 k).

It requests that a resolution be issued indicating the filing of the procedure.

Subsidiarily, a warning and, as a last resort, that the proposal contained in the Agreement of Initiation be moderated or adjusted.

EIGHTH: On February 8, 2023, the instructor of the procedure agreed to carry out the following evidence: <<1. The complaint filed by Mr. A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, and the report of prior investigation actions that are part of the procedure are reproduced for evidentiary purposes. 2. Likewise, the allegations to the agreement to initiate the referenced sanctioning procedure, presented by DIGI SPAIN TELECOM, S.L., and the accompanying documentation are reproduced for evidentiary purposes>>.

NINTH: On March 13, 2023, a proposal for resolution was made, proposing that the Director of the Spanish Agency for Data Protection sanction DIGI SPAIN TELECOM, S.L., with NIF B84919760, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 a) of the GDPR, with the corresponding sanction being a fine of 70,000 euros (seventy thousand euros).

TENTH: After the proposal for resolution was notified, the respondent requested an extension of the deadline to submit allegations, which was granted, and submitted a written statement of...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/18

allegations on April 4, 2023, in which, in summary, it is stated that it reiterates the allegations previously presented, and that the report issued by the European Union Cybersecurity Agency confirms that, to carry out a fraudulent SIM duplication, the scammer needs to have access to some of the personal data of the victim, a customer of the operator. That is to say, that cybercriminals have personal data of their victims prior to approaching the Mobile Network Operator.

It points out that this is what occurred in the present case, the victim lost control over their personal data in favor of the impersonator before the latter contacted DIGI.

"Furthermore, to emphasize, in the present case and as previously stated in the writings of this party, the store employee expressly states that they did carry out such verification, and there is no reason to doubt their statement without further argument than the result of the identity theft. Thus, there is a possibility that even following the protocol and having requested a copy of the ID, it could have been false. Moreover, the fact that a photocopy of that document was made would not have added any greater security to the operation.

This is why the responding party considers that the Proposal is not in accordance with the law, as it imposes on DIGI an obligation of result, consisting of the establishment of infallible measures, by attributing a violation of Article 6.1 of the GDPR based solely on the harmful result produced by the fraudulent intervention of a third party, without taking into account the diligence used and without considering the deployment of technically adequate and implemented measures.

DIGI cannot foresee or know what the applicable duty of diligence is.

Regarding the lack of proportionality of the proposed sanction and that, following the appropriate procedures, a resolution is issued indicating the filing of procedure No. PS/4881/2022."

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST. - The claiming party filed a complaint with this Agency on April 3, 2022, in which it is stated that on April 1, 2021, their mobile phone lost service, receiving several emails from two banking entities notifying them of attempts to access their account and the execution of several transfers via Bizum.

SECOND. - DIGI certifies that the duplication occurred on April 1, 2021, at 14:52 hrs. at a point of sale distributing DIGI products and services, and that the duplication could only be performed by the line holder and only in person at a distributor. The customer must show the original identity document, as photocopies are not valid, and the distributor must verify the data of the line number and identity document, which must match those recorded for the customer in the systems of the responding party.

THIRD. - It is recorded that DIGI, on April 12, 2021, proceeded to establish measures concerning the point of sale distributing DIGI products and services involved, as well as to remind them of their contractual obligations regarding the identification of DIGI customers. Likewise, they proceeded to limit access to the application to prevent possible unauthorized access.

FOURTH. - The claimant's mobile line was active, allegedly with fraudulent activity, from 14:52 hrs. to 19:22 hrs. on April 1, 2022.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Obligation Breached

The responding party is accused of committing an infringement for violating Article 6 of the GDPR, "Lawfulness of processing," which states in its paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

"1. Processing shall be lawful only if at least one of the following conditions is met:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) the processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/18

- c) the processing is necessary for compliance with a legal obligation to which the data controller is subject;

d) the processing is necessary to protect vital interests of the data subject or another natural person;

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) the processing is necessary for the purposes of legitimate interests pursued by the data controller or by a third party, provided that such interests do not override the interests or the fundamental rights and

freedoms of the data subject which require the protection of personal data, particularly when the data subject is a child. The provision in paragraph f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.”

III

Classification and qualification of the infringement

The infringement is classified in Article 83.5 of the GDPR, which considers the following as such:

“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) The basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.”

The LOPDGD, for the purposes of the statute of limitations for the infringement, qualifies in its Article 72.1 as a very serious infringement, with a statute of limitations of three years in this case, “b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679.”

In response to the allegations presented by the accused entity, the following should be noted:

Regarding the assertion that DIGI has not provided the alleged criminals with personal information of the claimant other than what they already had beforehand. Consequently, there has been no unauthorized processing of personal data.

Indeed, the issuance of a duplicate is not sufficient to carry out banking operations in the name of the holders; certainly, to complete the fraud, it is necessary for a third party to “impersonate” the data holder before the financial entity.

This, in principle, leads to processing outside the principle of lawfulness since a third party is processing data, as they have access to it, without any legal basis, in addition to the violation of other principles such as confidentiality.

For this reason, this is a process where the diligence provided by the operators is fundamental to prevent this type of fraud and violations of the GDPR. Diligence that translates into the establishment of appropriate measures to ensure that data processing is compliant with the GDPR.

Identical considerations apply to the actions of banking entities that provide payment services, in whose scope this type of fraud begins, as the third party has access to the credentials of the affected user and impersonates them.

As these entities are responsible for processing their clients' data, they have the same obligations as those indicated so far for the operators regarding compliance with the GDPR and the LOPDGD, as well as those derived from Royal Decree-Law 19/2018, of November 23, on payment services and other urgent financial measures.

From the Established Facts, it is inferred that DIGI has provided a duplicate SIM card to a third party other than the legitimate holder of the mobile line, after a third party bypassed the existing security policy, which evidences a breach of the duty to protect customer information.

Furthermore, DIGI claims that, “the store employee expressly states that they did carry out such verification, and their statement cannot be doubted without further argument than the result of the identity theft. Thus, there is a possibility that even following the protocol and having requested a copy of the ID, it could have been false. Moreover, the fact that a photocopy of that document was made would not have added greater security to the operation.”

Well, it should be noted that it is not enough to say that the employee checked the ID without being able to substantiate this claim in any way; it is not acceptable to state that the Agency does not allow photocopying/scanning IDs, as Article 5.2 of the GDPR states that “The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it (proactive responsibility),” since it is the controller, in compliance with their proactive responsibility obligations, who must implement the necessary technical and organizational measures, as expressed in Articles 24 and 25 of the GDPR.

The principle of proactivity transfers to the data controller the obligation not only to observe the principles governing processing but also to be able to demonstrate such compliance.

Article 5.2 of the GDPR is developed in Article 24 of the GDPR, which obliges the controller to adopt appropriate technical and organizational measures “to ensure and be able to demonstrate” that processing has been carried out in accordance with the GDPR.

The provision establishes:

“Responsibility of the data controller”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/18

“1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with this Regulation. Such measures shall be reviewed and updated as necessary.

2. When provided in relation to the processing activities, among the measures mentioned in paragraph 1, the implementation by the data controller of appropriate data protection policies shall be included.

3. Adherence to approved codes of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as elements to demonstrate compliance with the obligations of the data controller.”

Furthermore, Article 25.1 of the GDPR states that “Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of the data subjects.”

The lawfulness of the processing implies that personal data may only be processed by the data controller when one of the legitimizing bases listed in Article 6 of the GDPR is present.

Denying the occurrence of negligent conduct by DIGI would equate to acknowledging that its behavior—by action or omission—has been diligent. Obviously, we do not share this perspective of the facts, as the lack of due diligence has been evidenced. The judgment SAN of October 17, 2007 (rec. 63/2006) is very illustrative; starting from the premise that these are entities whose activities involve continuous processing of customer data, it indicates that “...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard.”

It is evidenced in the file that adequate security has not been guaranteed in the processing of personal data, given the result produced by the identity theft. That is to say, a third party has managed to access the personal data of the line holder.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/18

Regarding the fact that the criminals have not managed to obtain personal data from DIGI, which means that there can be no talk of a breach of protection measures, it should be noted that access to a duplicate of a SIM card that identifies its holder falls under the definition of personal data as per Article 4.1) of the GDPR.

As for DIGI's liability, it should be indicated that, in general, DIGI processes its customers' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary for the execution of a contract in which the data subject is a party or for the application at the request of the data subject of pre-contractual measures. In other cases, it bases the lawfulness of the processing on the grounds provided in Article 6.1.a), c), e), and f) of the GDPR.

On the other hand, to complete the fraud, it is necessary for a third party to "impersonate the identity" of the data holder in order to receive the duplicate of the SIM card. This, in principle, leads to processing outside the principle of legality since a third party is processing data, as they have access to it, without any legal basis, in addition to violating other principles such as confidentiality.

Certainly, the principle of responsibility provided in Article 28 of the LRJSP states: "Only individuals and legal entities may be sanctioned for acts constituting administrative infractions, as well as, when a law recognizes their capacity to act, the groups of affected parties, unions, and entities without legal personality and independent or autonomous estates, that are found responsible for them on the grounds of intent or negligence."

However, the manner of attributing responsibility to legal entities does not correspond to the forms of culpability that are attributable to human conduct, whether intentional or negligent. Thus, in the case of infractions committed by legal entities, although the element of culpability must be present, it necessarily applies differently than it does with individuals.

According to STC 246/1991, "(...) this distinct construction of the attribution of the authorship of the infraction to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject. Capacity to infringe and, therefore, direct reproachability that derives from the legal good protected by the norm that is infringed and the necessity for that protection to be truly effective and the risk that, consequently, the legal entity subject to compliance with that norm must assume" (in this sense, STS of November 24, 2011, Rec 258/2009).

To the above, it should be added, following the ruling of January 23, 1998, partially transcribed in the STS of October 9, 2009, Rec 5285/2005, and of October 23, 2010, Rec 1067/2006, that "although the culpability of the conduct must also be subject to proof, it should be considered in terms of the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it form part of the proven typical conduct, and that its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/18

Exclusion requires that the absence of such elements be proven, or in its normative aspect, that due diligence has been exercised by the party claiming their non-existence; it is not sufficient, in summary, for exculpation against a typically unlawful behavior to invoke the absence of fault.

Consequently, the lack of culpability is dismissed. The ultimate responsibility for the processing remains attributed to the controller, who is the one that determines the existence of the processing and its purpose. Let us remember that, generally speaking, operators process their customers' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary for the execution of a contract in which the data subject is a party (...). In this regard, DIGI has a network of sales representatives, points of sale, and authorized distributors through a distribution contract to offer DIGI's services. Among these services offered from their points of sale is the issuance of duplicates of SIM cards corresponding to a mobile phone line.

Regarding the breach of the principle of proportionality, the GDPR expressly provides for the possibility of gradation, through the provision of fines that can be modulated, taking into account a series of circumstances of each individual case.

As for the imposition of a warning, admonition, or the adoption of corrective measures in accordance with Article 58 of the GDPR, a deterrent fine is one that has a genuine deterrent effect. In this regard, the Judgment of the CJEU, of June 13, 2013, Versalis Spa/Commission, C-511/11, ECLI:EU:C:2013:386, states:

“94. Regarding, first of all, the reference to the Showa Denko/Commission judgment, previously cited, it should be noted that Versalis interprets it incorrectly. Indeed, the Court of Justice, when stating in paragraph 23 of that judgment that the deterrent factor is assessed taking into account a multitude of elements and not just the particular situation of the company in question, referred to points 53 to 55 of the conclusions presented in that case by Advocate General Geelhoed, who essentially pointed out that the deterrent multiplier coefficient may aim not only at a ‘general deterrence,’ defined as an action to disincentivize all companies, in general, from committing the infringement in question, but also at a ‘specific deterrence,’ consisting of deterring the specific defendant from infringing the rules again in the future. Therefore, the Court of Justice only confirmed, in that judgment, that the Commission was not obliged to limit its assessment to factors related solely to the particular situation of the company in question.”

“102. According to established case law, the objective of the deterrent multiplier factor and the consideration, in this context, of the size and overall resources of the company in question lies in the desired impact on the aforementioned company, as the sanction must not be insignificant, especially in relation to the financial capacity of the company (in this sense, see, in particular, the judgment of June 17, 2010, Lafarge/Commission, C-413/08 P, Rec. p. I-5361, paragraph 104, and the order of February 7, 2012, Total and Elf Aquitaine/Commission, C-421/11 P, paragraph 82).”

We must take into account the singular circumstances of the claim presented, through

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/18

from which it can be verified that, from the moment the impersonating person replaces the SIM, the victim's phone is left without service, transferring control of the line to the impersonators.

Consequently, their powers of disposition and control over their personal data are affected, which constitute part of the content of the fundamental right to data protection as indicated by the Constitutional Court in Judgment 292/2000, of November 30, 2000 (FJ 7). Thus, by obtaining a duplicate of the SIM card, access to contacts or applications and services that have a password recovery procedure involving the sending of an SMS with a code to modify passwords is enabled under certain circumstances. Ultimately, they can impersonate the identity of the affected individuals, being able to access and control, for example: email accounts; bank accounts; applications such as WhatsApp; social networks, such as Facebook or Twitter, and a long etcetera. In summary, once the access key is modified by the impersonators, the victims lose control of their accounts, applications, and services, which poses a significant threat. Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, with the aim of, under the principle of proactive responsibility, complying with and being able to demonstrate compliance, while respecting the fundamental right to data protection.

In the present case, it is established that on April 1, 2021, Digi processed the issuance of duplicates of the SIM card for line ***TELEFONO.1, belonging to the claimant.

However, it should be noted that SIM Swapping is a fraud that allows identity theft by hijacking the phone number through obtaining a duplicate of the SIM card.

In any case, the operator must be able to prove that for this specific case it followed the verification protocols implemented when requesting a duplicate of the SIM card.

The result was that the respondent issued the SIM card to a third party who was not the holder of the line.

In light of the above, DIGI fails to prove that this procedure was followed.

In fact, according to the identification procedure described by the respondent, the original identification document should have been verified, and had this operation been carried out correctly, the duplicate should have been denied.

The respondent has not been able to prove that the procedure implemented by itself was followed in this case, as, had it been done, the duplicate of the SIM card should have been denied.

Based on the above, in the analyzed case, the diligence employed by the respondent to identify the

person who requested a duplicate of the SIM card is called into question.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/18

In accordance with the available evidence, it is estimated that the conduct of the respondent violates Article 6.1 of the GDPR, constituting an infringement as defined in Article 83.5.a) of the aforementioned Regulation 2016/679.

In this regard, Recital 40 of the GDPR states:

“(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on another legitimate basis established by law, whether in this Regulation or under another Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation applicable to the data controller or the necessity of performing a contract to which the data subject is party or for the purpose of taking steps at the request of the data subject prior to entering into a contract.”

IV

Sanction of fine. Determination of the amount.

The determination of the sanction to be imposed in this case requires observing the provisions of Articles 83.1 and 2 of the GDPR, which respectively state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation referred to in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding to impose an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and detriment suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and detriment suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented in accordance with Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/18

- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or the processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or the processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

In this section, the LOPDGDD provides in its Article 76, titled “Sanctions and corrective measures”:
“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
 - b) The link between the infringer's activity and the processing of personal data.
 - c) The benefits obtained as a result of the commission of the infringement.
 - d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
 - e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
 - f) The impact on the rights of minors.
 - g) Having, when not mandatory, a data protection officer.
 - h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.
3. It shall be possible, additionally or alternatively, to adopt, when appropriate, the remaining corrective measures referred to in Article 83.2 of Regulation (EU) 2016/679.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

15/18

Digi requests that the following mitigating circumstances be considered:

- (I) “the absence of prior infringements” (art. 83.2 e) GDPR).
- (II) “At no time have special categories of data been processed” (art. 83.2 g).
- (III) “the cooperation with the supervisory authority by responding to the transfer of the complaint and providing the requested information,” Article 83.2 f) of the GDPR.
- (IV) “The absence of benefits obtained through the infringement,” Article 83.2 k) of the GDPR and 76.2 c) of the LOPDGDD.

None of the invoked mitigating circumstances are accepted.

Regarding (I) and (II), it should be noted that such circumstances can only operate as aggravating factors and in no case as mitigating factors.

The ruling made by the National Court in its SAN of May 5, 2021 (Rec. 1437/2020) regarding paragraph e) of Article 83.2 of the GDPR, concerning the commission of prior infringements:

“On the other hand, it considers that the absence of a prior infringement should be regarded as a mitigating factor. Well, Article 83.2 of the GDPR establishes that the circumstance 'e) any prior infringement committed by the controller or the processor' must be taken into account for the imposition of the administrative fine. This is an aggravating circumstance; the fact that the prerequisite for its application does not occur means that it cannot be taken into consideration, but does not imply or allow, as the claimant intends, its application as a mitigating factor.”

(III) Article 83.2.f) of the GDPR refers to “the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement.” The response of the respondent to the information request from the Inspection Subdirectorate did not fulfill those purposes, so it cannot be classified under that mitigating factor.

(IV) Regarding the application of Article 76.2.c) of the LOPDGDD, in connection with Article 83.2.k), the absence of benefits obtained, it should be noted that such circumstance can only operate as an aggravating factor and in no case as a mitigating factor.

Article 83.2.k) of the GDPR refers to “any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.” And Article 76.2c) of the LOPDGDD states that “2. In accordance with the

provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account: [...] c) The benefits obtained as a consequence of the commission of the infringement.” Both provisions mention as a factor that can be taken into account in the graduation of the sanction the “benefits” obtained, but not the “absence” of these, which is what DIGI claims.

Furthermore, according to Article 83.1 of the GDPR, the imposition of fines is governed by the following principles: they must be individualized for each particular case, be effective, proportionate, and dissuasive. The admission that the absence of benefits operates...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/18

As a mitigating factor, the absence of benefits is contrary to the spirit of Article 83.1 of the GDPR and to the principles governing the determination of the amount of the fine. If, following the commission of a GDPR infringement, it is classified as a mitigating factor that no benefits have been obtained, the deterrent purpose fulfilled by the sanction is partially nullified. Accepting DIGI's thesis in a case like the one at hand would imply introducing an artificial reduction in the sanction that should genuinely be imposed; the one that results from considering the circumstances of Article 83.2 GDPR that must indeed be evaluated.

The Administrative Litigation Chamber of the National Court has warned that the fact that not all elements constituting a modifying circumstance of liability, which by its nature is aggravating, are present in a specific case cannot lead to the conclusion that such a circumstance is applicable as a mitigating factor. The ruling made by the National Court in its judgment of May 5, 2021 (Rec. 1437/2020) - even though that resolution deals with the circumstance of section e) of Article 83.2 of the GDPR, the commission of previous infringements - is extrapolable to the issue raised, the claim of the respondent that the "absence" of benefits be accepted as a mitigating factor, given that both the GDPR and the LOPDGDD refer only to "the benefits obtained":

“On the other hand, it considers that the non-commission of a previous infringement should be appreciated as a mitigating factor. Well, Article 83.2 of the GDPR establishes that, among other things, the circumstance "e) any previous infringement committed by the controller or the processor" must be taken into account for the imposition of the administrative fine. This is an aggravating circumstance; the fact that the prerequisite for its application does not exist means that it cannot be taken into consideration, but it does not imply or allow, as the claimant intends, its application as a mitigating factor.”

In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purposes of determining the amount of the fine to be imposed on the respondent entity as responsible for an infringement classified in Article 83.5.a) of the GDPR and 72.1 b) of the LOPDGDD, the following factors are deemed concurrent in the present case:

As aggravating factors:

- The evident link between the business activity of the respondent and the processing of personal data of clients or third parties (Article 83.2.k of the GDPR in relation to Article 76.2.b of the LOPDGDD).

The Judgment of the National Court of 17/10/2007 (rec. 63/2006), in which, regarding entities whose activity involves continuous processing of client data, indicates that “...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/18

As mitigating factors:

The responding party proceeded to effectively resolve the incident subject to the claim (art. 83.2 c).

The balance of the circumstances contemplated in Article 83.2 of the GDPR, regarding the infringement committed by violating the provisions of Article 6.1 of the GDPR, allows for the imposition of a fine of 70,000 euros (seventy thousand euros).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on DIGI SPAIN TELECOM, S.L., with NIF B84919760, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, a fine of 70,000 euros (seventy thousand euros).

SECOND: TO NOTIFY this resolution to DIGI SPAIN TELECOM, S.L.

THIRD: To warn the sanctioned party that they must pay the imposed fine once this resolution becomes enforceable, in accordance with the provisions of art. 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in art. 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to art. 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no. IBAN: ES00-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/18

Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional

suspension terminated.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es